

UNIVERSIDADE DE MOGI DAS CRUZES
BACHARELADO EM ENGENHARIA DE SOFTWARE

VITOR HUGO OLIVEIRA TAVARES
IGOR AUGUSTO DOS SANTOS PEREIRA
RENATO MARTINS LOPES

DESENVOLVIMENTO DE SISTEMA SEGURO

Mogi das Cruzes

2026

VITOR HUGO OLIVEIRA TAVARES

DESENVOLVIMENTO DE SISTEMA SEGURO

Trabalho apresentado para o Prof. Fabiano Bezerra Menegidio sobre atividade relacionada à disciplina de Segurança da Informação do curso de Bacharelado em Engenharia de Software.

Mogi das Cruzes

2026

RESUMO

Este projeto apresenta o desenvolvimento de um sistema web de autenticação seguro e resiliente, estruturado para atender aos rigorosos padrões da norma ISO/IEC 27001 e às diretrizes da Lei Geral de Proteção de Dados (LGPD - Lei nº 13.709/2018). O objetivo principal consiste na implementação de uma arquitetura baseada no framework Flask e banco de dados PostgreSQL, reduzir vulnerabilidades comuns de aplicações web, como ataques de força bruta e injeção de SQL. A metodologia técnica adotada engloba a utilização do algoritmo de derivação de chaves Argon2id para o armazenamento seguro de credenciais em banco de dados, substituindo padrões obsoletos, e a integração de um Múltiplo Fator de Autenticação (MFA) baseado no protocolo TOTP (Time-Based One-Time Password) via biblioteca PyOTP. No âmbito da conformidade regulatória, o sistema garante a privacidade desde a concepção (Privacy by Design), implementando rotas de exclusão definitiva de registros (direito ao esquecimento) e anonimização de logs, bem como a exportação de dados estruturados em JSON, assegurando ao titular controle total sobre suas informações pessoais. Os resultados dos testes confirmam a eficácia das contramedidas contra intrusões e o pleno alinhamento técnico-jurídico da aplicação.

Palavras-chave: Autenticação Multifator; Criptografia Argon2; Segurança da Informação; LGPD; Flask.

ABSTRACT

This project presents the development of a secure and resilient web authentication system, structured to meet the strict standards of the ISO/IEC 27001 norm and the guidelines of the Brazilian General Data Protection Law (LGPD - Law No. 13,709/2018). The main objective is the implementation of an architecture based on the Flask framework and a PostgreSQL database, mitigating common web application vulnerabilities such as brute force attacks and SQL injection. The adopted technical methodology encompasses the use of the Argon2id key derivation algorithm for the secure storage of credentials in the database, replacing obsolete standards, and the integration of a Multi-Factor Authentication (MFA) based on the TOTP (Time-Based One-Time Password) protocol via the PyOTP library. Regarding regulatory compliance, the system ensures privacy by design, implementing routes for the definitive deletion of records (right to be forgotten) and log anonymization, as well as the export of structured data in JSON format, ensuring the data subject has full control over their personal information. The test results confirm the effectiveness of the countermeasures against intrusions and the full technical and legal alignment of the application.

Keywords: Multi-Factor Authentication; Argon2 Cryptography; Information Security; LGPD; Flask.

SUMÁRIO

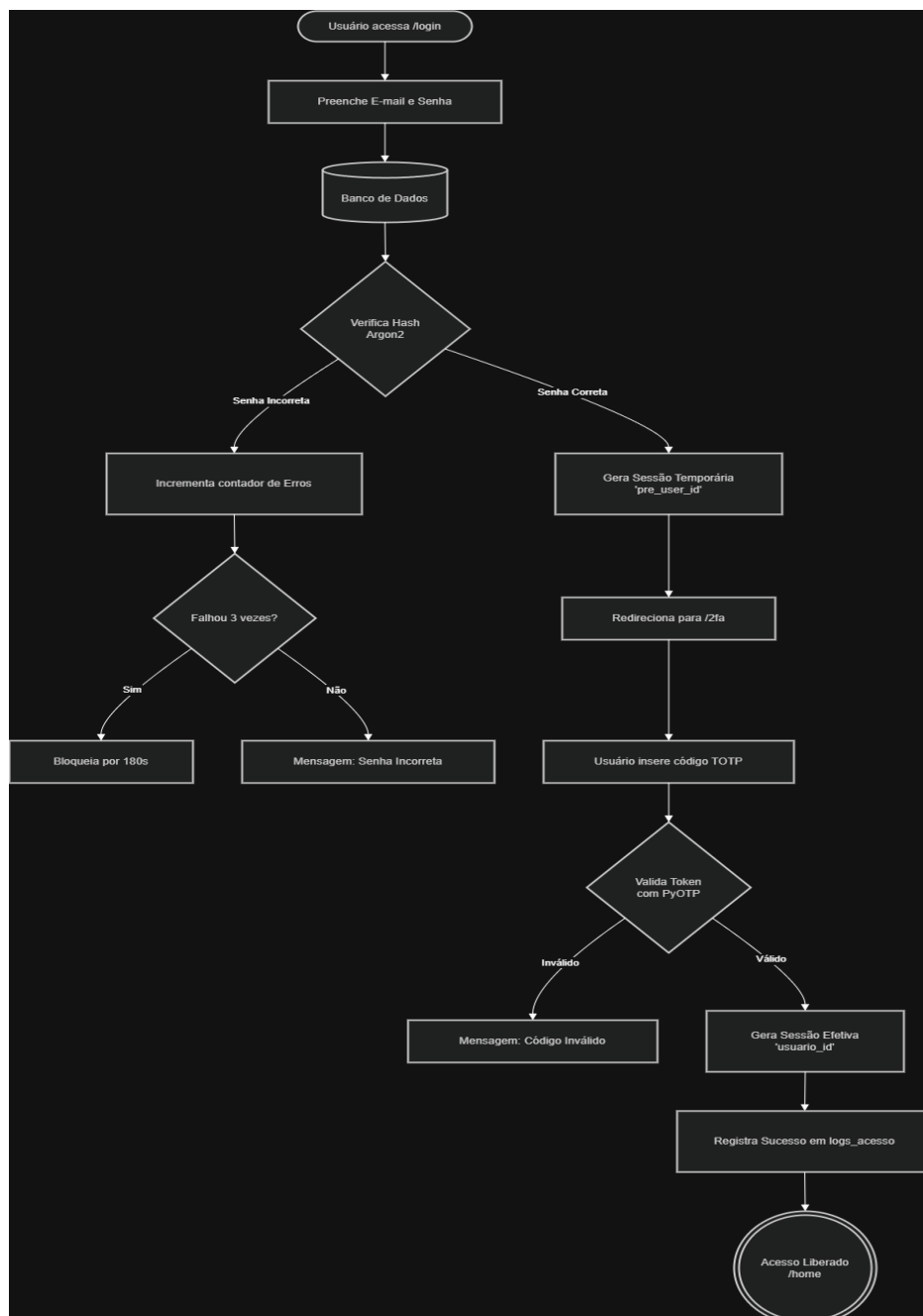
1. INTRODUÇÃO	4
2. ARQUITETURA DO SISTEMA	5
3. GESTÃO DE CREDENCIAIS E CRIPTOGRAFIA	6
4. MODELAGEM DE AMEAÇAS E CONTRAMEDIDAS)	7
5. CONFORMIDADE COM A LGPD	9
6. EVIDÊNCIAS DE TESTES E AUDITORIA	10
7. CONCLUSÃO	13

1. INTRODUÇÃO

No cenário digital contemporâneo, o vazamento de credenciais e a exploração de vulnerabilidades em sistemas de login representam algumas das maiores ameaças à segurança da informação. Para mitigar esses riscos, legislações como a Lei Geral de Proteção de Dados (LGPD) no Brasil e frameworks de segurança corporativa como a norma ISO/IEC 27001 exigem que os sistemas adotem controles de acesso robustos e proteção criptográfica de ponta a ponta. Este trabalho tem como objetivo descrever a arquitetura e os mecanismos de defesa implementados no "Projeto Autenticação". A aplicação foi desenhada para atuar não apenas como um portal de validação de usuários, mas como um ambiente auditável, onde princípios de minimização de dados e consentimento explícito guiam as transações no banco de dados.

2. ARQUITETURA DO SISTEMA

O projeto adota um padrão arquitetural monolítico em camadas, desenvolvido na linguagem Python 3. A camada de roteamento e controladores é gerenciada pelo framework Flask, responsável pela renderização Server-Side Rendering (SSR) via Jinja2. A persistência de dados ocorre em um banco de dados relacional PostgreSQL. O fluxo de dados segue um rigoroso controle de estado: ao iniciar o login, o usuário transita por uma sessão temporária (`pre_user_id`) que o impede de acessar as rotas protegidas da aplicação até que o segundo fator de autenticação (TOTP) seja processado com sucesso.



3. GESTÃO DE CREDENCIAIS E CRIPTOGRAFIA

A segurança de credenciais em repouso é garantida pela substituição de algoritmos vulneráveis por um padrão de estado da arte: o Argon2id (via biblioteca argon2-cffi). O Argon2 foi escolhido por ser resistente a ataques paralelos baseados em GPU e ataques de canal lateral (Side-Channel).

Para balancear segurança e performance do servidor, o algoritmo foi configurado com os seguintes parâmetros de custo: Time Cost (2): Determina o número de iterações, aumentando o tempo necessário para cada tentativa de quebra de hash. Memory Cost (65536 KB):

Exige alto consumo de RAM, inviabilizando ataques de dicionário em hardware otimizado (ASICs). Parallelism (2): Define a quantidade de threads utilizadas no processamento. Adicionalmente, a autenticação multifator (MFA) foi implementada seguindo a RFC 6238.

Os segredos de 32 caracteres gerados pela biblioteca PyOTP operam em uma janela de validade temporal estrita, invalidando o código do usuário após breves instantes.

4. MODELAGEM DE AMEAÇAS E CONTRAMEDIDAS

A superfície de ataque do sistema foi avaliada para garantir a resiliência contra as principais metodologias de intrusão e vulnerabilidades comuns em aplicações web. Abaixo, detalham-se os riscos identificados, os ativos afetados e as respectivas contramedidas implementadas no código-fonte do projeto:

4.1 Injeção de Código (SQL Injection)

1. Ativo Afetado: Banco de Dados (PostgreSQL).
2. Nível de Impacto: Crítico.
3. Contramedida / Mitigação: Utilização de queries SQL parametrizadas com placeholders (%) em todos os métodos do arquivo `usuario_dao.py`, impedindo a concatenação maliciosa e a execução de comandos indevidos.

4.2 Ataques de Força Bruta (Brute Force)

1. Ativo Afetado: Endpoint de Autenticação (/login).
2. Nível de Impacto: Alto.
3. Contramedida / Mitigação: Implementação de controle de Rate Limit na camada de serviço (`auth_service.py`). O sistema bloqueia novas tentativas de login por 180 segundos após 3 falhas consecutivas para o mesmo e-mail.

4.3 Exposição de Credenciais (Vazamento)

1. Ativo Afetado: Tabela de usuarios.
2. Nível de Impacto: Crítico.

3. Contramedida / Mitigação: Substituição de algoritmos vulneráveis pelo Key Derivation Function (KDF) Argon2id. A configuração com altos custos de memória e tempo inviabiliza ataques de dicionário ou força bruta otimizados por GPU.

4.4 Roubo ou Interceptação de Senha

1. Ativo Afetado: Contas de Usuário / Sessões de Acesso.

2. Nível de Impacto: Alto.

3. Contramedida / Mitigação: Obrigatoriedade de Autenticação de Dois Fatores (2FA) via protocolo TOTP (biblioteca pyotp). O acesso só é efetivado e a sessão liberada após a validação do token temporal de 6 dígitos do usuário.

4.5 Acesso Indevido a Dados Pessoais (Violação LGPD)

1. Ativo Afetado: Dados Pessoais (PII) e Logs de Auditoria.

2. Nível de Impacto: Alto.

3. Contramedida / Mitigação: Anonimização e exclusão de dados. A rota de exclusão de conta apaga definitivamente os dados identificáveis do titular e desvincula os logs (convertendo o usuario_id para NULL), mantendo a integridade da auditoria sem ferir a privacidade.

5. CONFORMIDADE COM A LGPD

O sistema atua como Controlador de Dados e processa apenas Dados Pessoais Diretos essenciais para a autenticação (Nome e E-mail). As seguintes funcionalidades garantem o direito do titular:

Consentimento (Art. 7º, Inciso I): O formulário de cadastro coleta o consentimento afirmativo, registrando o timestamp da ação e a versão do termo de privacidade associado.

Direito de Acesso e Portabilidade (Art. 18): O painel do usuário possui uma rota dedicada (/exportar-dados) que consolida os dados pessoais e os logs de tráfego em um arquivo formato JSON para download.

Direito à Eliminação: O recurso de "Excluir Conta" invoca uma rotina de deleção de todos os dados de identificação do indivíduo (PII). Os logs de acesso são mantidos por obrigatoriedade legal de rastreabilidade, porém sofrem anonimização (o campo `usuario_id` é convertido para nulo).

6. EVIDÊNCIAS DE TESTES E AUDITORIA

Evidência de Criptografia Argon2 no Banco de Dados

QueryQuery History

1

SELECT id, email, senha FROM usuarios;

	id [PK] integer	email character varying (100)	senha text
1	1	k9@email.com	\$2b\$12\$25McmREYlbBbpJ868/VxLee83xGzHIGAG2EdAX3hTNcp1Y1xyqixG
2	3	vitore@email.com	\$2b\$12\$HFWR34VUWT3kjL96zjbOi6RUVUjFMtszEN4p2yDUEu0kZjjoWOC
3	4	igor@email.com	\$2b\$12\$u7bx3qP6BaRqBqbQmIV/iO4NTWJc1cCNx1n0e/0mz01Bt1L983fzS
4	2	a10@email.com	\$2b\$12\$EgPUFFfOAdU/o69ywZiimul8sPTMBImI/R6U8/SpntTd9QNXvM2My
5	5	nariga@email.com	\$2b\$12\$8SYvplr0DVo9lSeXGvZZKuWRsxS75LzhjuzGbLjFAJBYfTCKMzAHG
6	6	vitortav@email.com	\$argon2id\$v=19\$m=65536,t=2,p=2\$c2SRgt86E/eKKxB4WV28wASWz/UlaHPcU58BUsha8zjIK5Wk8LIGif5YTsZQa/o...
7	8	luanlk@email.com	\$argon2id\$v=19\$m=65536,t=2,p=2\$WT4J7hT2URsaq7qQAuWDuw\$F3dRWGUzUe+5fHdQLdrr70kkrPwHRZqZm3rG...
8	9	vitinho@email.com	\$argon2id\$v=19\$m=65536,t=2,p=2\$jqQZtaVxUwyzkmC6gkd3TASalZcDJwqYbTA07Z09Dy5nhzKjjldyUb2WKTAX6v...

Termo de Consentimento e Conformidade com a LGPD

O SISTEMA DE AUTENTICAÇÃO

Criar conta

Preencha os dados para se cadastrar

NOME COMPLETO

Sau nome

E-MAIL

seu@email.com

SENHA

Mínimo 8 caracteres

Conformidade com a LGPD

Seus dados (nome e e-mail) serão utilizados exclusivamente para autenticação e segurança da conta. Não compartilhamos seus dados com terceiros.

▶

Ver detalhes dos dados coletados

☐

Li e concordo com o tratamento dos meus dados pessoais conforme descrito acima, em conformidade com a LGPD (Lei nº 13.709/2018).

Versão do consentimento: 1.0 - 04/06/2026 12:59:28

Criar conta e configurar 2FA

Já tem conta? Entrar

Bloqueio de Segurança Contra Ataques de Força Bruta

O SISTEMA DE AUTENTICAÇÃO

Bem-vindo

Entre com sua conta para continuar

⚠ Senha incorreta (2/3)

E-MAIL

kelvin9@email.com

SENHA

.....|

Entrar

ou

[Criar nova conta](#)

[Esqueci minha senha](#)

O SISTEMA DE AUTENTICAÇÃO

Bem-vindo

Entre com sua conta para continuar

E-MAIL

seu@email.com

SENHA

.....

Entrar

ou

[Criar nova conta](#)

[Esqueci minha senha](#)

Aguarde 176s para tentar novamente

Verificação de Múltiplo Fator de Autenticação (2FA)

O SISTEMA DE AUTENTICAÇÃO



Verificação 2FA

Digite o código de 6 dígitos gerado pelo seu app autenticador.

 Abra o Google Authenticator ou Authy e insira o código atual.

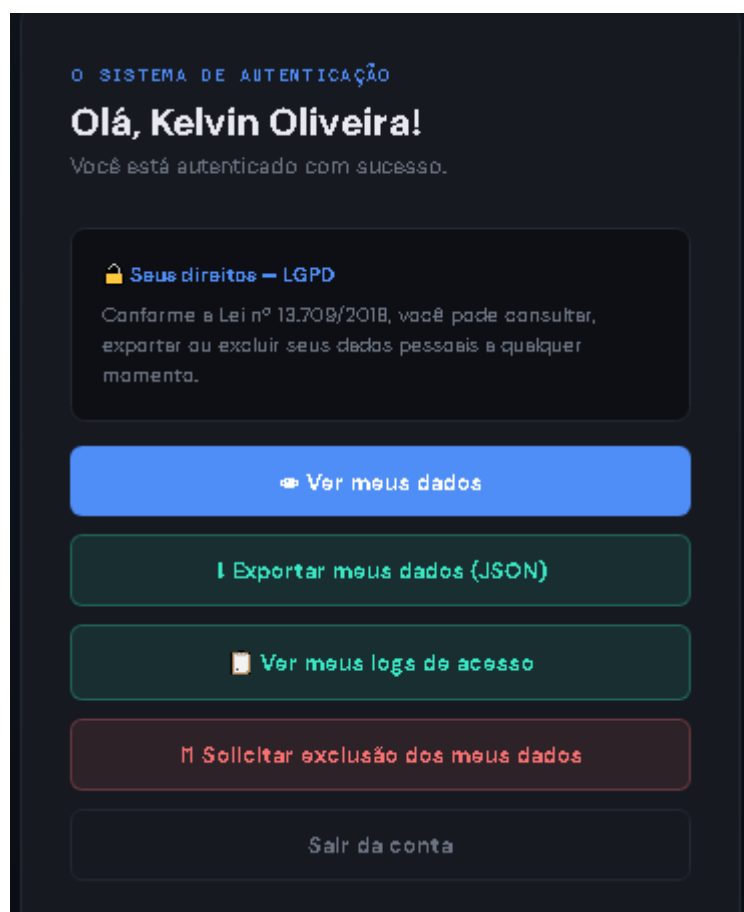
CÓDIGO DE VERIFICAÇÃO

2 3 3 6 5 5 |

Verificar e Entrar

[← Voltar para o login](#)

Painel de Direitos do Titular (Exportação e Exclusão)



7. CONCLUSÃO

O desenvolvimento do "Projeto Autenticação" cumpriu com êxito os requisitos propostos de confidencialidade, integridade, disponibilidade e conformidade legal. A substituição do hashing tradicional pelo Argon2, alinhada à obrigatoriedade do TOTP, blindou as contas dos usuários contra vazamentos em massa. A implementação das rotas de deleção e exportação de dados comprova que a engenharia de software moderna deve tratar a privacidade não como um complemento, mas como o núcleo do design arquitetural do sistema.